MedalMC network plan: review and recommendations

Review of the planned server architecture (Java, Bedrock, panel) with concrete fixes before launch.

> **Verdict: the plan is solid.** The fundamentals are in place: the box IP is in no public DNS record, the backends only listen on the internal Docker bridge, 25565 is restricted to TCPShield ranges, and the panel sits behind Cloudflare. The points below cover the gaps that most often go wrong on networks like this one. None of them require a redesign.

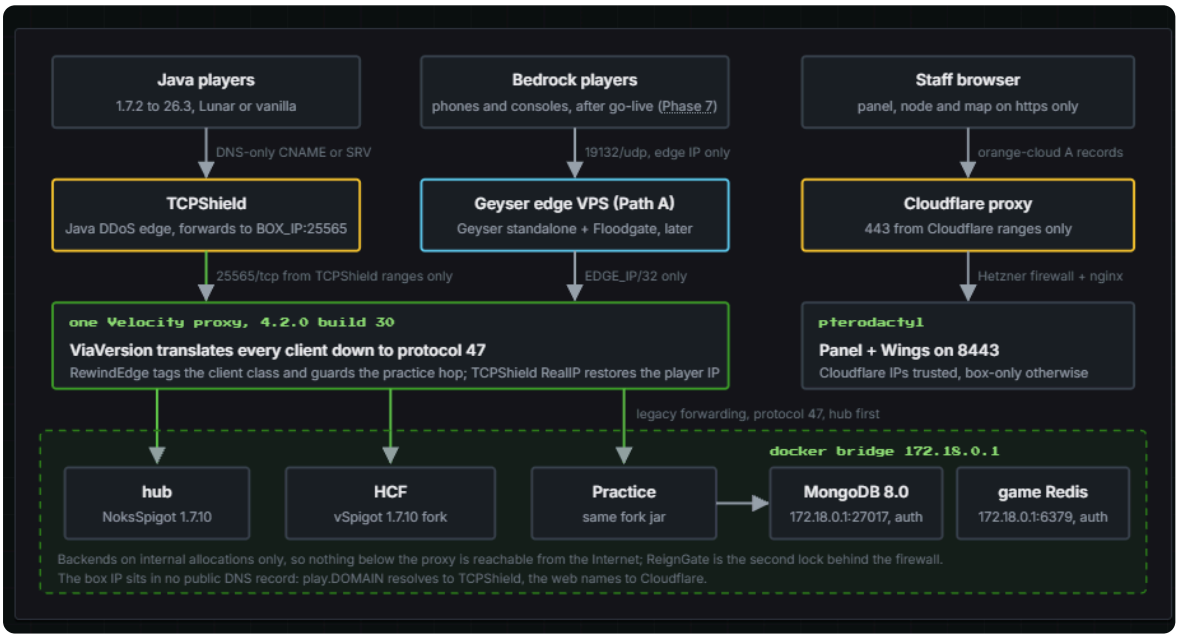


Figure 1. Planned architecture as reviewed.

What is already done right

- **Origin hidden.** `play.DOMAIN` resolves to TCPShield; web names resolve to Cloudflare; the box IP is not published.
- **Narrow firewall.** 25565/tcp only from TCPShield ranges, 443 and 8443 only from Cloudflare ranges, the Geyser edge allowed as a single `/32`.
- **Backends unreachable from the Internet.** Hub, HCF and Practice run on internal allocations; legacy forwarding is acceptable because of this, and ReignGate adds a second lock.
- **One protocol target.** ViaVersion on the proxy translates every client down to protocol 47, so the 1.7.10 forks never see modern clients directly.
- **Bedrock isolated on its own edge.** An attack on the Geyser VPS does not reach the main box.
- **Databases with auth** and a separate game Redis.

Priority overview

#	Recommendation	Priority	When
1	Let Geyser connections through the TCPShield plugin	High	Before Phase 7
2	Test Floodgate names against the 1.7.10 plugins	Medium	Before Phase 7
3	Keep Bedrock players out of ranked Practice	Low	Before Phase 7
4	UDP DDoS filtering on the Geyser edge VPS	Medium	Before Phase 7
5	Apply firewall and nginx rules to IPv6 too	High	Before launch
6	Send panel mail through an external SMTP service	High	Before launch
7	nginx default server reveals nothing	High	Before launch
8	Check DNS history; rotate IP if it was ever exposed	Medium	Before launch
9	Bind Docker ports explicitly, harden Redis	Medium	Before launch
10	Restrict Wings SFTP (2022); mind the Cloudflare upload limit	Medium	Before launch
11	Off-site backups with a tested restore	High	Before launch
12	Reduce single-box risk (config in git, panel 2FA)	Low	After launch
13	External monitoring and alerts	Medium	Launch week
14	Confirm the full Via stack on Velocity	Medium	Before launch

A. Bedrock (Phase 7)

1. The TCPShield plugin can reject Geyser High

The TCPShield RealIP plugin normally drops any connection that does not arrive through TCPShield. Geyser standalone connects to Velocity directly from `EDGE_IP`, so Bedrock players may be kicked on join. Two options:

- Whitelist `EDGE_IP` in the TCPShield plugin config, or
- Move both paths to the PROXY protocol and drop the RealIP plugin. Enable PROXY protocol for the backend in the TCPShield dashboard, then:

```
# velocity.toml
haproxy-protocol = true

# Geyser config.yml
java:
  use-proxy-protocol: true
```

With `haproxy-protocol` on, every connection must carry a PROXY header, so switch TCPShield and Geyser over at the same moment.

2. Floodgate names versus 1.7.10 plugins Medium

Floodgate prefixes Bedrock names (default `.`), and names can exceed 16 characters. Many 1.7.10-era plugins assume `[A-Za-z0-9_]{3,16}`. Test faction creation, chat formatting, punishments and any Mongo profile keyed by name before go-live. Also confirm whether the Floodgate backend plugin runs on the 1.7.10 fork; if not, keep it on Velocity only, and features that need the Floodgate API on the backends (such as Bedrock forms) will not be available.

3. Bedrock in ranked Practice Low

Touch and controller players under 1.8 combat give uneven hit registration. Allow Bedrock on hub and HCF, but keep them out of ranked Practice. RewindEdge already guards the Practice hop and can enforce this.

4. UDP protection on the Geyser edge Medium

The Bedrock edge is exposed on 19132/udp, and TCPShield does not cover it. Host the edge VPS with a provider that filters game UDP traffic. If it does go down, only Bedrock is affected, which is the point of the edge design.

B. Keeping the origin IP hidden

5. IPv6 High

Hetzner assigns an IPv6 /64 by default. Check that the Hetzner firewall, nginx and Docker rules cover IPv6 as well. Otherwise "443 from Cloudflare only" only holds for IPv4. If IPv6 is not needed, disable it on the box.

6. Panel email High

If Pterodactyl sends mail from the box itself, the origin IP ends up in the `Received` headers of every email (password resets, invites). Use an external SMTP provider such as Postmark, Mailgun or Brevo.

7. nginx default server High

A scanner that connects to the bare IP must get nothing back: no page and no certificate with our domain names. A certificate served on the bare IP is how services like Censys link an IP to a domain. The Cloudflare-only firewall already blocks this; the default server is the second layer.

```
# nginx 1.19.4+: catch-all that reveals nothing
server {
  listen 80 default_server;  listen [::]:80 default_server;
  return 444;
}
server {
  listen 443 ssl default_server;  listen [::]:443 ssl default_server;
  ssl_reject_handshake on;
}
```

8. DNS history Medium

If any domain ever pointed directly at this IP, history services such as SecurityTrails still show it. Check this once; if it was exposed, request a new IP before launch. The same applies to plugins or scripts that post the server address anywhere public.

C. Docker, databases and panel

9. Explicit Docker binds and Redis hardening Medium

Published Docker ports bypass ufw/iptables on the host. The external Hetzner firewall catches this, but bind every port explicitly to the bridge and never to `0.0.0.0`:

```
-p 172.18.0.1:27017:27017      # MongoDB
-p 172.18.0.1:6379:6379        # game Redis
```

```
# redis.conf
bind 172.18.0.1
protected-mode yes
requirepass <long random secret>
# Redis 7+: prefer an ACL user without dangerous commands, e.g.
user game on ><secret> ~* &* +@all -@dangerous
user default off
```

If you remove dangerous commands this way, first check that no plugin depends on `KEYS` or `CONFIG`.

10. Wings SFTP and uploads Medium

Wings SFTP (port 2022) cannot go through the Cloudflare proxy. Allow it only from staff IPs, or put it behind Tailscale or WireGuard. Cloudflare Free also caps request bodies at 100 MB, so large uploads through the panel will fail. Use SFTP for worlds and big jars.

D. Resilience

11. Off-site backups High

Backups are not in the plan yet. HCF data is what players care about most. Back up MongoDB and the server volumes daily, to storage outside the box (for example a Hetzner Storage Box or S3), and test a restore at least once before launch.

```
# daily, e.g. 04:30 via cron
mongodump --uri "$MONGO_URI" --archive --gzip > /backup/mongo-$(date +%F).gz
restic -r sftp:uXXXX@uXXXX.your-storagebox.de:/medalmc \
  backup /backup /var/lib/pterodactyl/volumes
restic forget --keep-daily 14 --keep-weekly 8 --prune
```

12. Single-box risk Low

The proxy, all backends, both databases and the panel run on one machine. That is fine for launch, but keep the Velocity, plugin and nginx configs in a git repository so the network can be rebuilt on a new box quickly. A panel compromise gives access to everything, so enforce 2FA for all staff accounts and keep panel admins to a minimum. Later, consider moving the panel to a small separate VPS.

13. Monitoring Medium

- Uptime Kuma on a separate machine that pings `play.DOMAIN` through TCPShield and the panel through Cloudflare.
- **spark** on the backends for TPS and lag profiling.
- Alerts to a private staff Discord channel.

14. Via stack on Velocity Medium

Supporting 1.7 clients on a protocol 47 backend needs all three plugins on the proxy: **ViaVersion** (newer clients), **ViaBackwards** and **ViaRewind** (1.7 clients; ViaRewind depends on ViaBackwards). Keep them on matching release versions and update them together.

Suggested order of work

1. **Before launch:** 5, 6, 7, 11, then 8, 9, 10, 14.
2. **Launch week:** 13.
3. **Before Phase 7 (Bedrock):** 1, then 2, 4, 3.
4. **After launch:** 12.

MedalMC is part of Medal Network. Review prepared by Codastra (codastra.nl). Based on the planned architecture in Figure 1. Config snippets are examples and should be checked against the versions actually deployed.